

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

System and Information Integrity Policy and Procedures (SI)

System and Information Integrity Policy and Procedures (SI)

Table of Contents

1.0. Document Purpose 2

2.0. Scope 2

3.0. Policy Conflict 2

4.0. Roles and Responsibilities 2

5.0. Management Commitment 3

6.0. Coordination Among Agency Entities 3

7.0. Compliance 3

8.0. Procedures 4

9.0. Document Details 17

10.0. Review 17

11.0. Records Management 17

12.0. Public Records Exceptions 17

13.0. Definitions 18

14.0. Abbreviations 19

Appendix A: Office of Information Technology Information Assets and Services 21

System and Information Integrity Policy and Procedures (SI)

1.0. Document Purpose

The purpose of this document is to define the State of Maine policy and procedures that are in place to ensure system and information integrity for State of Maine information assets (see Definitions). This part of the security program is focused on protecting the confidentiality (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets through the timely identification, reporting, and remediation of system flaws, malicious code, and unauthorized changes. This document corresponds to the System and Information Integrity (SI) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1]

2.0. Scope

2.1. This policy applies to all State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Policy Conflict

If this policy conflicts with any applicable law or union contract, the terms of the existing law or contract may prevail.

4.0. Roles and Responsibilities

4.1. Agencies:

4.1.1. Manage agency data in a secure manner.

4.1.2. Ensure that any contracts for vendor-hosted or managed agency information systems adhere to any pertinent Federal regulations, State regulations, and Office of Information Technology (OIT) policies, procedures, and standards.

4.1.3. Ensure agency personnel are aware of penalties for noncompliance.

4.1.4. Develop and implement agency-level policy and procedures to meet additional pertinent system and information integrity statutory requirements.

4.2. The Office of Information Technology (OIT):

4.2.1. Assigns an owner for each infrastructure information asset (for example, network, firewall) it supports (see the appendix).

4.3. OIT Information Asset Owners:

1 https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

4.3.1. Ensure that systems and information integrity protections are in place for their assigned information asset(s).

4.3.2. Implement security directives.

4.3.3. Protect information system memory from unauthorized code execution.

4.3.4. Utilize standard operating procedures to manage required changes.

4.3.5. Utilize integrity verification tools to detect unauthorized changes to software and information.

4.3.6. In collaboration with IT Procurement and agencies, hold contracted other parties that host State information assets accountable to this Policy and Procedures.

4.4. OIT Information Security Office (ISO)

4.4.1. Identifies and reports information system flaws.

4.4.2. Performs scheduled information system security scans.

4.4.3. Protects information systems from malicious code.

4.4.4. Monitors information systems.

4.5. IT Procurement:

4.5.1. In collaboration with Information Asset Owners and agencies, hold contracted other parties that host State information assets accountable to this Policy and Procedures.

5.0. Management Commitment

The State of Maine is committed to following this policy and the procedures that support it.

6.0. Coordination Among Agency Entities

6.1. OIT provides system information and integrity at the enterprise level for infrastructure consumed by agency information systems.

6.2. Agencies coordinate with OIT account managers, application development managers, and client technologies support staff to address agency-specific system and information integrity requirements.

6.3. Application development managers serve as information asset owners for the agency information systems that their teams support.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine system and information integrity protection processes.

8.1. Flaw Remediation (SI-2, (1), (2))

8.1.1. Agencies, in consultation with OIT, ensure that appropriate mechanisms are in place to identify, report, and correct flaws in agency information systems.

8.1.2. The Information Security Office employs the following mechanisms, in accordance with the above:

8.1.2.1. Subscribes to Multi-State Information Sharing and Analysis Center (MS-ISAC) alerts and MITRE Common Vulnerabilities and Exposures (CVE) updates and notifications.

8.1.2.2. Distributes alerts, updates, and notifications to information asset owners.

8.1.2.3. Scans information systems weekly and monthly at set intervals.

8.1.2.4. Reviews all security-related reports.

8.1.3. OIT information asset owners take the following actions to correct information system flaws:

8.1.3.1. Conduct security testing in accordance with deployment certification procedures (see the Application Deployment Certification Policy[2] and the Infrastructure Deployment Policy[3]).

8.1.3.2. Install operating system patches and hot fixes (see Definitions).

8.1.3.3. Install security patches.

8.1.3.4. In collaboration with agencies and IT Procurement, utilize support and maintenance contracts to engage vendors in correcting identified flaws in off-the-shelf software or firmware.

---

[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ApplicationDeploymentCertification.pdf
[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/Infrastructure-Deployment-Certification.pdf

8.1.4. OIT information asset owners utilize standard operating procedures to manage change. They:

8.1.4.1. Use the centrally managed OIT Change Advisory Board (CAB) for change management.

8.1.4.1.1. Production changes must follow the OIT Change Management Policy[4].

8.1.4.2. Install security-relevant software and firmware at defined intervals:

8.1.4.2.1. The Information Security Office ensures that antivirus definition files are updated daily.

8.1.4.2.2. Information asset owners install patches at predefined intervals for the information assets they manage (such as security patches for hosting environments).

8.1.4.2.3. The time between vulnerability identification and remediation is monitored and documented through the State's vulnerability management and tracking systems.

8.1.4.2.4. Exceptions to remediation timelines must be formally documented, justified, and approved through the established risk acceptance or waiver process.

8.1.4.2.5. Additional details regarding tracking, escalation, and exception handling are defined in the Vulnerability Scanning Procedure (RA-5)[5].

8.1.4.2.6. Automated patch management tools are employed to facilitate flaw remediation across supported technology stacks. These tools are integrated into operational environments where feasible and practical.

8.1.4.2.6.1. Patches are deployed initially in non-production environments for validation and compatibility testing. This process is mandatory for all critical systems, especially those with complex interdependencies.

[4] https://www.maine.gov/oit/policies/ChangeManagementPolicy.pdf
[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/VulnerablityScanningProcedure.pdf

8.1.4.2.6.2. Workstations and endpoint devices leverage real-time or near-real-time vendor-provided patch channels. These patches are distributed automatically to ensure continuous protection against emerging threats.

8.1.4.2.6.3. Application and network infrastructure components are monitored for vendor patch releases. Patches are evaluated, tested where appropriate, and applied upon availability in accordance with the system's risk level and operational requirements.

8.1.4.2.6.4. Vulnerability scanning tools are used to identify systems with missing patches or outdated software components. These scan results validate patch deployment, prioritize remediation actions, and ensure ongoing compliance with flaw remediation timelines.

8.1.4.2.6.5. Information asset owners install patches, hot fixes, and service packs as necessary to address specific issues, such as identified critical or zero-day vulnerabilities, as determined by the CISO or designee when such issues cannot wait for the next scheduled cycle.

8.1.4.2.6.6. Security-relevant software and firmware updates are only deployed once it has been determined safe to do so. However, some updates, such as those for workstations and endpoints, may occur automatically through approved, trusted mechanisms.

8.1.4.2.7. Previous versions of security-relevant software and firmware components shall be removed following the successful installation of updated versions, to eliminate potential vulnerabilities associated with outdated components.

8.1.4.2.7.1. In most cases, approved patching mechanisms automatically overwrite or update existing components in place. However, where multiple versions are allowed to coexist, or where automated tools do not ensure full removal, asset owners are responsible for confirming that outdated or unsupported versions are removed or otherwise rendered inaccessible.

8.1.4.2.7.2. Automated configuration and vulnerability management tools shall be used, where possible, to detect and remediate the presence of outdated versions.

8.1.4.2.8. Information asset owners install patches, hot fixes, and service packs, as necessary, to address specific issues, such as identified critical vulnerabilities, that cannot wait for the next scheduled cycle.

8.1.4.2.8.1. This determination is made in collaboration with the Information Security Office.

8.1.4.2.8.2. Alternatively, interim compensating controls, approved by the Information Security Office, may be used to address identified vulnerabilities.

8.1.5. The Information Security Office employs automated mechanisms (monthly scans), independent of the patching schedule, to determine the flaw remediation status of information system components.

8.2. Malicious Code Protection (SI-3)

8.2.1. Agencies, in consultation with OIT, ensure that malicious code (see Definitions) protections are in place to detect and eradicate malicious code at agency information system entry and exit points.

8.2.2. OIT information asset owners implement malicious code protections at entry and exit points for the information asset they are responsible for. For example, Network Services utilizes firewalls to perform real-time scans at network entry and exit points, detecting and eradicating malicious code.

8.2.3. OIT information asset owners keep malicious code protection mechanisms current by implementing new product releases when they become available. OIT information asset owners determine whether to update malicious code protections automatically or manually.

8.2.4. The Information Security Office employs products at information system entry and exit points to detect and eradicate malicious code.

8.2.4.1. The Information Security Office ensures antivirus definition files are updated daily. Additionally, the Information Security Office configures products to perform weekly scans of information systems and to conduct real-time scans of files from external sources.

8.2.4.2. The Information Security Office configures products to block and quarantine malicious code, and to alert the Information Security Office, in response to malicious code detection.

8.2.4.3. The Information Security Office reviews quarantined code for potential information system impact, and, if appropriate, sends it to the vendor for further analysis.

8.2.4.4. Quarantines are adjusted based on the risk level of the finding (for example, considering false positives identified during analysis).

8.2.5. OIT manages malicious code protection centrally, at the enterprise level, as follows:

8.2.5.1. The Information Security Office and OIT information asset owners plan, implement, assess, authorize, and monitor malicious code protection products.

8.2.5.2. The Information Security Office consumes the MS-ISAC as a resource to plan, implement, assess, authorize, and monitor Albert.[6]

8.3. Information System Monitoring (SI-4, (1), (2), (4), (5), (7), (10), (11), (12), (14), (23), (24))

8.3.1. Agencies, in consultation with OIT, ensure their agency information systems are monitored to detect attacks and indicators of potential attacks, as well as unauthorized local, network, and remote connections.

8.3.2. In accordance with the above, OIT performs the following information system monitoring:

[6] https://www.cisecurity.org/services/albert-network-monitoring/

8.3.2.1. The Information Security Office employs products to detect attacks and indicators of potential attacks, as well as unauthorized local, network, and remote connections.

8.3.2.2. The Information Security Office receives notifications for improper logins, as well as unexpected behaviors, to identify unauthorized use of information systems.

8.3.2.3. The Information Security Office deploys products strategically within information systems to collect essential information and at ad hoc locations within information systems to track specific types of transactions (such as hypertext transfer protocol (HTTP) traffic that bypasses HTTP proxies).

8.3.2.4. OIT information asset owners perform information system monitoring for the information asset they are responsible for. For example, Network Services employs firewalls to detect attacks and indicators of potential attacks, as well as unauthorized local, network, and remote connections.

8.3.2.5. The Information Security Office and information asset owners protect information obtained from intrusion-monitoring tools from unauthorized access, modification, and deletion by requiring team administrator credentials.

8.3.2.5.1. Access to this information must be granted based on the principle of least privilege (see Definitions).

8.3.2.5.2. Selected security and technology owners have visibility into encrypted communications strictly for legitimate business needs. Access is limited to only those individuals necessary to perform essential functions and safeguard the network.

8.3.3. The Information Security Office heightens the level of information system monitoring activity whenever there is an indication of increased risk to organizational operations, assets, individuals, other organizations, or the Nation, based on law enforcement information, intelligence information, or other credible sources of information. Heightened activity may include any of the following actions, based on the Information Security Office's assessment of the situation:

8.3.3.1. The Information Security Office increases the involvement of external security analysts.

8.3.3.2. The Information Security Office and information asset owners leverage additional external incident response resources.

8.3.3.3. The Information Security Office consults with the Attorney General's Office and security legal analysts to obtain legal opinion regarding information system monitoring activities in accordance with applicable Federal or State laws, executive orders, directives, policies, or regulations.

8.3.4. The Information Security Office employs products to provide intrusion detection.

8.3.5. Network Services employs intrusion detection and intrusion prevention systems on network entry to detect attempted intrusions into the enterprise.

8.3.5.1. Logs are automatically imported into a central security information and event management (SIEM) repository for anomaly alerting and processing.

8.3.5.2. The information security team conducts continuous monitoring to identify threat indicators. All system logs are monitored, and anomalous activity triggers alerts in the agency's Security Information and Event Management (SIEM), following audit policies and procedures. After-hours network monitoring is performed by internal staff and a third-party security provider with SIEM access. The State uses geofencing to block connections originating outside of Maine. Indicators of compromise (IOC) addresses from alerts and notices are entered for blocking. Connection durations are limited by policy and sessions are disconnected if time limits are exceeded.

8.3.5.3. Host-based monitoring tools are deployed to support continuous monitoring. All system logs are analyzed for threat indicators, and anomalous activity triggers alerts in the agency's Security Information and Event Management (SIEM). After-hours monitoring is performed by internal staff and third-party providers with SIEM access.

8.3.6. Network Services employs firewall intrusion detection and intrusion prevention systems.

8.3.7. Network Services employs products to monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.

8.3.8. Network Services employs access points and wireless local area network controllers for over-the-air detection and reporting.

8.3.9. The Information Security Office and OIT information asset owners employ systems that alert teams when indications of compromise or potential compromise occur.

8.3.9.1. Automated mechanisms are employed, where available, to alert security personnel of unusual or inappropriate activities that have security implications. Manual mechanisms are used in instances where automatic mechanisms are not implemented.

8.3.9.2. When suspicious events are detected, designated agency personnel are notified, and necessary actions are taken to address the suspicious events.

8.3.9.3. Automated monitoring tools detect activities that may indicate inappropriate or unusual behavior with security or privacy implications. When such events occur, the system automatically generates alerts and notifies designated agency personnel or roles responsible for responding to these incidents. This ensures timely awareness and enables prompt action to address potential security or privacy issues.

8.4. Security Alerts, Advisories, and Directives (SI-5)

8.4.1. Agencies, in consultation with OIT, ensure that mechanisms are in place to receive security alerts, advisories, and directives on an ongoing basis that are pertinent to their agency information systems.

8.4.2. The Information Security Office team receives and disseminates system security alerts, advisories, and directives on an ongoing basis from multiple sources, including:

8.4.2.1. MS-ISAC emails;

8.4.2.2. Albert suspicious internet traffic report; and

8.4.2.3. The Department of Homeland Security.

8.4.3. The Information Security Office generates internal security alerts, advisories, and directives as deemed necessary (for example, in response to a known issue or threat or to strengthen the State's security posture).

8.4.3.1. The audience for the communication is determined based on the nature of the alert, advisory, or directive (technical, agency end user, agency leadership).

8.4.3.2. Agency communication is coordinated through the OIT account managers, communications manager, or application development managers.

8.4.3.3. OIT technical communication is handled directly by the Information Security Office.

8.4.3.4. The Information Security Office establishes security directive implementation time frames and notifies OIT information asset owners as part of the communication.

8.5. Security Function Verification (SI-6)

8.5.1. Agencies, in consultation with OIT, ensure that mechanisms are in place to verify the correct operations of organizationally defined security functions (see Definitions) that are pertinent to their agency information systems.

8.5.2. The Information Security Office identifies defined security functions at an enterprise level.

8.5.3. Agencies must identify any supplemental security functions necessary to meet regulatory requirements.

8.5.4. Agencies collaborate with their application development managers and/or account managers to implement supplemental security functions for OIT-supported agency information systems.

8.5.5. The Information Security Office works with information asset owners (typically system administrators) to review and verify configuration settings and deployment certifications to ensure security functions are implemented.

8.5.6. On a scheduled basis (at a frequency determined by the information asset owner in collaboration with the Information Security Office), information asset owners conduct patching and verification.

8.5.7. If there is a failed security test, the Information Security Office notifies and works with information asset owners to address identified issues.

8.5.8. The information asset owner takes necessary action to address any identified issues (e.g., shut down or restart the information asset, etc.).

8.6. Software, Firmware, and Information Integrity (SI-7, (1), (7), (10))

8.6.1. Agencies, in consultation with OIT, ensure that integrity verification tools are employed to detect unauthorized changes to software and information.

8.6.2. OIT information asset owners utilize integrity verification tools to detect unauthorized changes to software and information (such as network and security infrastructure tools).

8.6.3. Firmware deployed in production is sourced exclusively from trusted, authorized vendors or original equipment manufacturers (OEMs). This ensures the integrity of boot firmware and mitigates risks associated with unauthorized or compromised firmware components.

8.6.4. The Information Security Office conducts integrity scans of information systems on an as-needed basis to assess the integrity of software and information.

8.6.5. The Information Security Office classifies unauthorized security-relevant changes that are detected and reported and determines whether they are subject to formal incident-response procedures.

8.6.6. The Security Information and Event Management (SIEM) system is monitored 24/7 by the Security Operations Center (SOC) and the after-hours security service provider. The system generates alerts for unauthorized activity, including unauthorized elevation of system privileges. Detected events are tracked, monitored, and retained for historical analysis and potential legal action. Additional details regarding SIEM detection and response capabilities are documented in the Audit and Accountability Policy and Procedures.

8.7. Spam Protection (SI-8, (2))

8.7.1. Agencies, in consultation with OIT, ensure that spam (see Definitions) protection mechanisms are employed at agency information system entry and exit points to detect and act on unsolicited messages.

8.7.2. OIT information asset owners employ spam protections, in accordance with the above, for the information assets that they manage.

8.7.2.1. In Microsoft 365, email messages are automatically protected against spam and malware by Exchange Online Protection (EOP).

8.7.2.2. EOP has built-in inbound and outbound malware filtering to help protect the State of Maine from malicious software, and built-in spam filtering to help protect the State of Maine from both receiving and sending spam (for example, in case of compromised accounts).

8.7.2.3. Admins do not need to set up or maintain the filtering technologies because they are enabled by default.

8.7.2.4. For SharePoint Online, antimalware protection is automatically provided for files that are uploaded and saved to document libraries. Microsoft provides this antimalware protection engine, also integrated into Exchange. This antimalware service runs on all SharePoint Online content frontends.

8.8. Information Input Validation (SI-10)

8.8.1. This section applies to any information asset where OIT has ownership of the code.

8.8.2. Agencies, in consultation with OIT, ensure that their agency information systems check the validity of defined information inputs for accuracy, completeness, validity, and authenticity as close to the point of origin as possible.

8.8.2.1. Agencies define the information inputs subject to this validation and the method through which validation takes place, in consultation with OIT.

8.8.2.2. OIT application development managers ensure their teams implement input validation mechanisms for their assigned agency systems, in accordance with the above.

8.8.2.3. The Information Security Office validates the implementation through regular application vulnerability scanning.

8.9. Error Handling (SI-11)

8.9.1. Agencies, in consultation with OIT, ensure that their agency information systems generate error messages that provide information necessary for corrective action, without revealing information that could be exploited by adversaries. In addition, agencies must ensure that their information systems reveal error messages only to defined personnel and roles.

8.9.1.1. Agencies review error message content, prior to implementation, to ensure that no information is revealed that could be exploited by adversaries.

8.9.1.2. Agencies define the personnel and roles to whom error messages are revealed.

8.9.1.3. OIT application development managers ensure that their teams implement error messages, in accordance with the above, for their assigned agency systems.

8.9.1.4. The Information Security Office team validates the implementation through regular application vulnerability scanning.

8.10. Information Handling and Retention (SI-12)

8.10.1. Agencies, in consultation with OIT, ensure that information asset output is handled and retained in accordance with data classification handling requirements, applicable State and Federal laws, directives, policies, regulations, standards, and operational requirements.

8.10.1.1. Agencies define information handling and retention standards in accordance with the above.

8.10.1.2. The OIT information asset owners implement agency-defined information handling and retention standards for the information asset they manage (for example, backup and recovery).

8.10.1.3. Archiving data according to specific business requirements is part of the application development process.

8.10.1.4. Personally Identifiable Information (PII) collected, used, shared, and disposed of by the organization or its partner agencies must be limited to the minimum elements necessary to fulfill legally authorized business purposes. PII may only be collected and processed to support a legitimate and legally authorized business function.

8.10.1.4.1. Agency-designated data owners are responsible for determining the necessity of each PII element collected, maintaining appropriate documentation and disclosure of:
a. What PII is being collected
b. Determination of the sensitivity classification as specified in the Data Classification Policy
c. The legal or business purpose for collection
d. How the PII is maintained, shared, and protected
e. Retention schedules and disposal methods
f. Compliance with applicable privacy regulations

8.10.2. File Transfer Retention Period:

8.10.2.1. Files and folders transferred via file transfer systems will be retained for the least amount of time necessary to achieve the data exchange, but no longer than seven (7) days from the date of file or folder creation.

8.10.2.2. Historical records must not be stored on file transfer systems. Any long-term data retention needs must be met and supported by other technology solutions.

8.10.2.3. Agencies must avoid the use of PII for research, testing, or training unless no suitable alternative exists and with the appropriate authorization to do so.

8.10.2.3.1. Any such use must employ data minimization techniques and comply with applicable state and federal privacy laws, regulations, and organizational standards.

8.10.2.4. Information disposal must be conducted in a manner that prevents unauthorized access, loss, or misuse.

8.10.2.4.1. Dispose of PII according to retention schedules using techniques defined in the Media Protection Policy and Procedures (e.g., shredding, secure deletion, degaussing).

8.10.2.4.2. Verify third-party compliance with contractual data disposal obligations during the contract

lifecycle, particularly at contract termination or data-handling milestones.

8.11. Memory Protection (SI-16)

8.11.1. Agencies, in consultation with OIT, ensure that security safeguards are used to protect information system memory from unauthorized code execution.

8.11.2. For information assets where OIT has control of the code, the Information Security Office employs malicious code protection products to protect information system memory from unauthorized code execution.

8.12. Personally Identifiable Information Quality Operations (SI-18, (4), (5))

8.12.1. Agencies must ensure the accuracy, relevance, timeliness, and completeness of Personally Identifiable Information (PII) throughout the information life cycle. Inaccurate or outdated PII must be corrected or deleted in accordance with applicable regulatory requirements and organizational responsibilities.

8.12.2. Requests for correction or deletion of PII submitted by individuals or their designated representatives shall be honored in accordance with the terms disclosed at the time of original data collection and as required by applicable state and federal regulations.

8.12.3. When PII is corrected or deleted, designated data owners must notify organization-defined authorized recipients and affected individuals as required by applicable state and federal regulations.

8.13. De-Identification (SI-19, (3), (4))

8.13.1. Elements of Personally Identifiable Information (PII) must be removed from datasets in accordance with applicable laws, policies, and records management schedules. The Maine State General Schedules provide retention and disposition authorizations for records commonly created and maintained by state agencies to support administrative, personnel, and fiscal activities. These schedules apply to records in all formats, including electronic records, and establish the minimum retention requirements that must be followed. Agencies are expected to use the Maine State General Schedules in conjunction with agency-specific retention schedules.

8.13.1.1. The effectiveness of de-identification efforts must be evaluated in accordance with the requirements defined in these applicable schedules.

8.13.2. PII elements that are not required for an approved data release must be removed from datasets prior to their release. De-identification must be performed in accordance with applicable laws, regulations, and organizational policies.

8.13.3. Direct identifiers in datasets must be removed, masked, encrypted, hashed, or replaced using methods that prevent re-identification, unauthorized disclosure, or misattribution. Obfuscation methods must meet applicable encryption standards and avoid the use of values that could be associated with real individuals.

9.0. Document Details

9.1. Initial Issue Date: July 19, 2019

9.2. Latest Revision Date: October 31, 2025

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[7]

9.6. Waiver Process: Waiver Policy[8]

9.7. Distribution: Internet[9]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[10] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[11] certain public records exceptions may limit the disclosure of agency records related to information technology infrastructure and systems, as well as to security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

---

[7] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[9] https://www.maine.gov/oit/policies-standards
[10] https://www.maine.gov/sos/arc/records/state/GS1Administrative.pdf
[11] https://legislature.maine.gov/statutes/1/title1sec402.html

13.0. Definitions

13.1. Availability: Timely and reliable access to and use of information assets.

13.2. Compensating Control: An alternative mechanism instituted to mitigate a legitimate vulnerability when the mechanism that would remediate the vulnerability properly is deemed impractical. If utilized, compensating controls must provide the same, or greater, level of defense as would be attained through the proper remediation. Compensating controls may be used until full remediation can be undertaken.

13.3. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including a means for protecting personal privacy and proprietary information.

13.4. Data Minimization: A privacy principle requiring that only the minimum necessary amount of PII be collected, used, or retained to fulfill a specific, legally authorized purpose.

13.5. Data Owner: The individual or role responsible for determining the purpose, classification, handling, and retention of a specific information asset or dataset.

13.6. De-identification: The process of removing or transforming personally identifiable information (PII) in a dataset to prevent the identification of individuals. Techniques may include removal, masking, encryption, hashing, or replacement of direct identifiers.

13.7. Direct Identifier: A data element that can be used on its own to identify an individual, such as a name, Social Security number, or biometric record.

13.8. Geofencing: A security technique that restricts or monitors network access based on geographic location, often used to block connections originating outside a defined area.

13.9. Hot Fix: A type of patch applied directly to a live system to correct a specific issue without waiting for the next planned update cycle.

13.10. Information Asset: Used interchangeably with Information System. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.11. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.12. Malicious Code: Unwanted files or programs that can cause harm to a computer or compromise data stored on a computer. Classifications of malicious code include viruses, worms, and Trojan horses.

13.13. Obfuscation: The deliberate transformation of data to conceal its original meaning or structure, often used to protect sensitive information.

13.14. Patch: A piece of software code added to an existing program to fix a vulnerability, error, or functionality issue. Patches are typically applied as part of a regular maintenance cycle and may include security updates, bug fixes, or performance improvements.

13.15. Patch Management: The process of identifying, acquiring, testing, and deploying software updates (patches) to correct vulnerabilities and improve system functionality.

13.16. Personally Identifiable Information (PII): Information that can be used to distinguish or trace an individual's identity, such as name, Social Security number, date of birth, or biometric records, either alone or when combined with other personal or identifying data.

13.17. Principle of Least Privilege: A security principle whereby users are assigned the minimum access necessary to perform their job responsibilities. Access is granted for the shortest duration possible.

13.18. Security Function: The hardware, software, and/or firmware of the information system responsible for enforcing the system security policy and supporting the isolation of code and data on which the protection is based.

13.19. Security Operations Center (SOC): A centralized team or facility responsible for monitoring, detecting, analyzing, and responding to cybersecurity incidents and threats across an organization’s information systems.

13.20. Service Pack: A collection of updates, fixes, or enhancements to a software program delivered as a single installable package.

13.21. Spam: Unsolicited, usually commercial messages (such as emails, text messages, or internet postings) sent to a large number of recipients or posted in a large number of places.

13.22. Vulnerability Scanning: The automated process of identifying security weaknesses in systems, applications, or networks by comparing configurations against known vulnerabilities.

14.0. Abbreviations

14.1. BIOS: Basic Input/Output System

14.2. CAB: Change Advisory Board

14.3. CVE: common vulnerabilities and exposures

14.4. DAFS: Department of Administrative and Financial Services

14.5. EOP: Exchange Online Protection

14.6. FOAA: [Maine] Freedom of Access Act

14.7. HTTP: Hypertext Transfer Protocol

14.8. IOC: Indicator of Compromise

14.9. ISO: [OIT] Information Security Office

14.10. MS-ISAC: Multi-State Information Sharing and Analysis Center

14.11. NIST: National Institute of Standards and Technology

14.12. OEM: Original Equipment Manufacturer

14.13. OIT: Office of Information Technology

14.14. SIEM: security information event management

14.15. UEFI: Unified Extensible Firmware Interface

Appendix A: Office of Information Technology Information Assets and Services

Information Asset/Service	Description	Owner
Business applications	OIT-developed applications to support specific business functions	Enterprise Shared Services
Network monitoring	Network activity monitoring	Security Operations Center (SOC)
Intrusion detection system	Malicious activity monitoring	SOC
Physical access (Badges)	Identification badges	SOC
Security infrastructure	Information systems security tools	SOC
Backups	Digital media backups and Enterprise-level backup, recovery, and storage services	Computing Infrastructure and Services
Directory services (Active Directory and supporting services)	Authentication and authorization	Computing Infrastructure and Services
Email (Office 365)	Email	Computing Infrastructure and Services
SQL servers: SQL databases	SQL infrastructure and services	Computing Infrastructure and Services
Storage	Data storage	Computing Infrastructure and Services
Virtual machine environment	Virtual machine infrastructure	Computing Infrastructure and Services
Windows Servers operating platform	Windows servers operating platform	Computing Infrastructure and Services
Oracle database	Oracle database	Enterprise Data Services
Oracle middleware	Oracle middleware	Enterprise Data Services
Unix	Variety of physical and virtual servers (HP, Sun, Oracle) and Operating Systems (Linux, Solaris)	Enterprise Data Services
Distributed Denial of Service (DDoS) protection	Distributed Denial of Service (DDoS) protection	Network and Voice Services
Network core	Redundant core	Network and Voice Services
Network services	Switches, routers, etc.	Network and Voice Services
Voice services	Analog telephony	Network and Voice Services
Voice over IP (VoIP)	Digital telephony	Network and Voice Services
Wireless	Wireless networking	Network and Voice Services

Information Asset/Service	Description	Owner
Domain Name Service (DNS)	Domain name – IP mapping	Network Security
Remote access/Virtual Private Network (VPN)	Secure remote access	Network Security
Reverse Proxy	Reverse proxy	Network Security
Web Application Firewall (WAF)	Filter, monitor, and block HTTP traffic	Network Security